PARABELLUM IO — GRC COMPLIANCE DASHBOARD

Security & Compliance Audit Report

GRC-2026-7037

appsecco/dvna

CONDITIONAL PASS | Score: 54% | Tier 2 — Risk-Informed

NIST CSF 2.0

Generated	Prepared By	Platform	Classification
13/05/2026, 23:20:21	Mirza Fahad Raza	SonarQube SAST	CONFIDENTIAL

2. Executive Summary



Compliance Score

CONDITIONAL PASS

⚠️ CONDITIONAL PASS — remediation required within 30 days.

The appsecco/dvna pipeline was assessed against the NIST CSF 2.0 standard.0 issues were analyzed across 1 unique CWE weaknesses, producing an audit score of **54%**.

NIST CSF Maturity Tier	**Tier 2 — Risk-Informed**
Overall Audit Score	**54/100**
Total Issues Scanned	**0**
Unique CWE Weaknesses	**1**
Critical	**0**
High	**0**
Medium	**1**
Low	**0**
Overall Risk Score	**3.1 / 10**

3. NIST CSF 2.0 Function Breakdown

GV — GOVERN	ID — IDENTIFY	PR — PROTECT
100%	100%	58%
PASS	PASS	FAIL

DE — DETECT	RS — RESPOND	RC — RECOVER
96%	100%	100%
WARN	PASS	PASS

3b. Control Mapping — CWE Technical Findings

CWE ID	VULNERABILITY	CVSS	SEVERITY	POSSIBLE ATTACKS	ISSUES	RISK IMPACT
CWE-693	**Protection Mechanism Failure**	5.0	Medium	Security Control Bypass, Unspecified Exploitation	4	A general weakness in security mechanisms that may allow various forms of exploitation dep...

4. Failed NIST Controls

PR.AC-01 PR.AC-01 — FAIL

[CRITICAL] [POL-C01] Missing USER instruction. Container runs as root by default.

[CRITICAL] [POL-C01] Missing USER instruction. Container runs as root by default.

PR.PT-01 PR.PT-01 — FAIL

[CRITICAL] [POL-C01] Missing USER instruction. Container runs as root by default.

[CRITICAL] [POL-C01] Missing USER instruction. Container runs as root by default.

DE.CM-01 Networks and network services are monitored to find potentially adverse events. FAIL

[MEDIUM] [POL-C03] No HEALTHCHECK instruction defined.

[MEDIUM] [POL-C03] No HEALTHCHECK instruction defined.

4b. Governance & Policy Alignment

NIST FUNCTION	SCORE	STATUS	KEY CONTROLS	RECOMMENDED ACTION
GOVERN	100%	PASS	GV.RM-01, GV.OC-01	Establish risk governance policies and assign ownership.
IDENTIFY	100%	PASS	ID.AM-01, ID.RA-01	Complete asset inventory and risk assessment.
PROTECT	58%	FAIL	PR.DS-01, PR.AA-01	Enforce least-privilege, patch management, and encryption.
DETECT	96%	WARN	DE.CM-01, DE.CM-08	Deploy SIEM and continuous vulnerability scanning.
RESPOND	100%	PASS	RS.MA-01, RS.AN-01	Document and test incident response playbooks.
RECOVER	100%	PASS	RC.RP-01	Define recovery time objectives (RTO/RPO) and test backups.

5. Detailed Findings & Remediation

CWE-693 Protection Mechanism Failure — Medium — CVSS 5

A general weakness in security mechanisms that may allow various forms of exploitation depending on the specific context.

T1562 · A05:2021 · CAPEC-122

4 issues · 2 files · Est. effort: **1 hour**

Remediation: Review security controls. Apply defense-in-depth. Follow secure coding guidelines.

6. Compliance Gap Matrix

CONTROL AREA	NIST CSF	STATE	GAP	PRIORITY
Access Control	PR.AA-01	Partial	PROTECT score 58% — requires improvement	P2 High
Data Security	PR.DS-01	Partial	PROTECT score 58% — requires improvement	P2 High
Vulnerability Mgmt	DE.CM-08	Implemented	Meets baseline	P3 Medium
Secure Coding	PR.PS-01	Partial	PROTECT score 58% — requires improvement	P2 High
Logging & Monitoring	DE.CM-01	Implemented	Meets baseline	P3 Medium
Incident Response	RS.MA-01	Implemented	Meets baseline	P3 Medium
Risk Governance	GV.RM-01	Implemented	Meets baseline	P3 Medium
Asset Management	ID.AM-01	Implemented	Meets baseline	P3 Medium

⚠️ 7. Risk Register

✅ No Critical or High risks to register.

🖇️ 8. Audit Attestation

Report ID	GRC-2026-7037
Report Date	13/05/2026, 23:20:21
Project Name	appsecco/dvna
Project Key	appsecco_dvna
CI/CD Platform	SonarQube SAST Integration
Tools Used	SonarQube (SAST), CWE Database, NIST CSF 2.0 Mapping Engine
Scan Coverage	0 issues, 1 CWEs, 3 failed controls
Frameworks Assessed	NIST CSF 2.0
Overall Verdict	CONDITIONAL PASS
Report Generation	Auto-generated by GRC Compliance Dashboard
Prepared By	Mirza Fahad Raza

⚠️ **Disclaimer:** This report is machine-generated evidence supporting human audit review. It is not a substitute for a formal third-party audit. Results are based on static analysis and automated CWE/NIST mapping. Manual review by a qualified security professional is recommended before using this report for regulatory compliance purposes.

GRC-2026-7037 · appsecco/dvna · CONFIDENTIAL